CMMC Level 2 Readiness & Assessment Prep on Google Workspace (NIST SP 800-171)

Implementation Solution Guide

Version 1.0.0 · 2026-07-06

Contents

Executive Summary 4

Outcome . . . 4

Approach . . . 4

Why it is low-risk . . . 4

The boundary we hold . . . 5

Solution Overview 5

What this is . . . 5

The problem it solves . . . 5

How it works — the reference model . . . 6

The deployment model (house standard) . . . 7

Benefits . . . 7

Limitations (boundary restated) . . . 7

Requirements 7

1. Workspace edition/add-on that supports the regulated-workload controls . . . 8

2. A defined CUI boundary input (users, groups, Shared Drives, data flows) . . . 8

3. Assessor / C3PAO and compliance-owner engagement . . . 8

4. Baseline of the existing Assured Controls / data-region posture . . . 9

5. API access for the assessment and evidence tooling . . . 9

6. Change-control window scoped to CUI-boundary changes . . . 9

Global Requirements — Google Workspace & Gemini Solutions 10

1. Google Workspace / Cloud Identity tenant . . . 10

2. Source Microsoft 365 / Entra environment (for migration & coexistence) . . . 10

3. DNS control for the routed domains . . . 11

4. Identity & provisioning source of truth . . . 11

5. A pilot scope (OU / group) and change control . . . 11

6. Security, compliance & governance stakeholders . . . 11

Implementation 12

Stage 1 — Assess (read-only, no changes) . . . 12

Stage 2 — Design . . . 13

Stage 3 — Configure (against the boundary OU) . . . 14

Stage 4 — Pilot (`CUI – Pilot – Org`) . . . 15

Stage 5 — Validate & evidence . . . 15

Stage 6 — Expand & sustain . . . 16

Testing & Validation 16

T1 — Boundary membership is correct . . . 16

T2 — External sharing is restricted (AC) . . . 17
T3 — Context-aware access enforces (AC) . . . 17
T4 — 2-Step Verification / keys enforced (IA) . . . 17
T5 — DLP detects and acts on CUI (SI/MP) . . . 17
T6 — Audit logging and export work (AU) . . . 17
T7 — Data region / encryption posture (SC/MP) . . . 18
T8 — App / API access controlled (CM) . . . 18
T9 — Evidence package is complete and indexed . . . 18
T10 — SSP and POA&M; are complete (CA) . . . 18
Troubleshooting 19
Authentication & API access . . . 19
Throttling / rate limits . . . 19
Evidence gaps . . . 20
DLP behaves unexpectedly . . . 20
Boundary drift & scope errors . . . 20
Edition-gated features . . . 21
SSP / POA&M; generation . . . 21
Rollback . . . 21
Best Practices 21
Boundary discipline . . . 21
Evidence hygiene . . . 22
Control-map as single source of truth . . . 22
Change safety . . . 22
Least privilege & credential safety . . . 22
Keep the assessment boundary where it belongs . . . 23
Continuous monitoring . . . 23
Deliverables Summary 23
Documentation . . . 23
The 5 Python tools . . . 24
Outputs you finish with . . . 25
Appendix A — PowerShell Scripts 26

Executive Summary

Outcome

Your organization holds **Controlled Unclassified Information (CUI)** on Google Workspace and must reach **CMMC Level 2** — the **110 security requirements of NIST SP 800-171** — to remain eligible for DoD work. This solution takes the tenant from *controls-unmapped, boundary-undefined, no-evidence* to **assessment-ready**: the CUI boundary is defined and enforced, the applicable NIST 800-171 controls are mapped to concrete Workspace configuration, the controls are applied and **evidenced**, and the **System Security Plan (SSP)** and **Plan of Action & Milestones (POA&M)** are complete — the exact posture a **C3PAO** expects to find at the start of a Level 2 assessment.

Approach

A **CUI-boundary-first, control-family-driven** playbook on the house model **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**:

1. **Define the CUI boundary** — a dedicated `CUI – Boundary – Org` organizational unit that fixes assessment scope.
1. **Map all 14 NIST 800-171 families** to real Workspace mechanisms (context-aware access, 2-step verification, DLP, Vault retention, audit-log export, data-region/encryption, admin separation) in a single **control-map matrix**.
1. **Configure, pilot, and evidence** each control against the boundary — pilot-first, with pass/fail gates and a documented rollback for every high-impact change.
1. **Generate the SSP and POA&M** from the completed control map, for the compliance owner to review and own.

Five read-only **Python tools** (Google Admin SDK / Reports / Drive APIs) do the measuring: a control-status assessment, an evidence collector/exporter, a CUI-boundary exposure checker, an SSP/POA&M draft generator, and a scope/config helper.

Why it is low-risk

- **Pilot-first with rollback.** Every enforcing control (DLP, sharing, context-aware access, 2SV) is proven on a pilot group before fleet enforcement; each has a one-lookup rollback scoped to the boundary OU — never the whole tenant.
- **Read-only, safe-by-default tooling.** The tools require only least-privilege read-only scopes; they cannot change the posture they measure, and no credentials or keys live in code.
- **Evidence-driven, not asserted.** Control status is *measured* from the live tenant, so the SSP and POA&M reflect reality, not optimism.

The boundary we hold

This engagement delivers **readiness** — control mapping, configuration method, and evidence, plus the SSP and POA&M. It does **not** produce a CMMC assessment result, decide NIST 800-171 applicability/scoping, interpret ITAR/DFARS, or represent you before a C3PAO. Those determinations remain with your **assessor, compliance officer, and legal counsel**. The result is a tenant that is **configured, evidenced, and assessment-ready** — at a fraction of open-ended readiness-consulting cost.

Solution Overview

What this is

This solution is a **readiness and assessment-preparation playbook** for organizations that handle **Controlled Unclassified Information (CUI)** on **Google Workspace** and must reach **CMMC Level 2** — the maturity level that maps to the **110 security requirements of NIST SP 800-171** across **14 control families**. It takes an enterprise from "we hold CUI in Workspace but our controls are unmapped and unevidenced" to "the CUI boundary is defined, the applicable NIST 800-171 controls are mapped to concrete Workspace configuration, the controls are applied and **evidenced**, and the **System Security Plan (SSP)** and **Plan of Action & Milestones (POA&M)** are in hand" — the state a **C3PAO (Certified Third-Party Assessment Organization)** expects to find at the start of a Level 2 assessment.

It builds on and references the organization's existing **Assured Controls / ITAR / DFARS data-region posture** (the separate regulated-workload solution) but is the distinct **certification-journey** product: its job is to produce the *control mapping, configuration method, and evidence* that a CMMC assessment consumes.

> ***Critical boundary — read first.*** *This is **readiness and preparation**, not assessment, certification, or legal interpretation. The solution provides the **technical control mapping, configuration procedure, and evidence artifacts**. It does **not** — and cannot — produce a CMMC assessment *result*, decide **NIST 800-171 applicability/scoping** for your organization, interpret **ITAR / DFARS 252.204-7012 / DFARS 252.204-7019/7020/7021**, or schedule/represent a C3PAO assessment. Every one of those is a **determination reserved to your organization's assessor, compliance officer, and legal counsel**. Where this document cites NIST SP 800-171 or CMMC, it cites them at the **framework level** to structure the technical work — it never asserts that a given configuration "satisfies" a control as a matter of assessment fact. Treat control-satisfaction language throughout as "*configured to support*," pending your assessor's determination.*

The problem it solves

A defense-supply-chain organization that has standardized on Google Workspace for mail, files, collaboration, and meetings, and that receives or generates CUI under a DoD contract, faces a recurring, expensive gap:

- The **110 NIST 800-171 requirements** are written technology-neutrally; nobody has mapped them to the

specific Workspace setting, admin path, or API that implements each one.

• The **CUI boundary** — which users, groups, organizational units (OUs), Shared Drives, and data flows are *in scope* — has never been drawn, so the assessment scope is undefined and unbounded.

• Controls may in fact be *configured*, but there is **no evidence** — no exported configuration, no audit-log extract, no screenshots — to show an assessor.

• There is **no SSP** describing how each requirement is met, and **no POA&M** tracking the gaps, so the organization cannot even submit a self-assessment score to **SPRS**, let alone host a C3PAO.

The result is a stalled certification, repeated ad-hoc consulting, and contract risk. This solution replaces that with a **repeatable, evidenced, self-guided path**.

How it works — the reference model

The solution organizes the work around a **CUI-boundary-first, control-family-driven** reference model on Google Workspace:

1. **Define the CUI boundary.** A dedicated `CUI – Boundary – Org` **organizational unit** (and, where the design calls for it, a `CUI – Enclave – Org` **sub-OU**) collects the users, groups, and Shared Drives that store, process, or transmit CUI. Everything inside the boundary is **in assessment scope**; everything outside is explicitly out (subject to your assessor's scoping determination).

1. **Map the 14 families to Workspace capability.** Each of the 14 NIST 800-171 families — **Access Control (AC), Awareness & Training (AT), Audit & Accountability (AU), Configuration Management (CM), Identification & Authentication (IA), Incident Response (IR), Maintenance (MA), Media Protection (MP), Personnel Security (PS), Physical Protection (PE), Risk Assessment (RA), Security Assessment (CA), System & Communications Protection (SC), and System & Information Integrity (SI)** — is mapped to the Workspace/Cloud-Identity mechanism that implements it: context-aware access, 2-step verification / security keys, DLP, Vault retention, audit logs and log export, client-side / default encryption, data-region and Assured Controls, admin-role separation, and so on. The mapping is captured in a `NIST 800-171 – Control Map – Org` **matrix** (control → Workspace setting → status → evidence pointer), the single spreadsheet that drives the rest of the engagement.

1. **Configure the controls** against the boundary OU, pilot-first, following the house deployment model, each configured artifact named to a consistent convention.

1. **Evidence every control.** For each control the solution captures the **configuration state** (exported policy/setting via Admin SDK) and the **operational evidence** (audit-log extract from the Reports API) into an `Evidence – CUI Boundary – <date>` **package**.

1. **Author the SSP and POA&M.** The completed control map feeds a `SSP – CUI Boundary – Org` document (one implementation statement per requirement) and a `POA&M – CUI Boundary – Org` register (one row per not-yet-met or partially-met requirement, with owner and milestone).

1. **Reach an assessment-ready gate** — controls configured + evidenced, boundary enforced, SSP/POA&M complete — at which point the organization engages its C3PAO. **The assessment itself and its outcome are out of scope.**

The deployment model (house standard)

All production changes follow **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**, pilot-first, with explicit **pass/fail gates** and a **documented rollback** for every high-impact change (DLP enforcement, sharing restriction, context-aware access, log export, encryption). Nothing enforced fleet-wide until it has passed on the `CUI – Pilot – Org` group.

Benefits

- **Assessment-ready, not just "secure."** The deliverable is the exact evidence + SSP + POA&M an assessor asks for — configured, exported, and organized to the 110 requirements.
- **Boundary discipline.** A defined, enforced CUI boundary shrinks and stabilizes assessment scope.
- **Repeatable and evidenced by tooling.** Five Python tools read the live tenant to produce the control-status map, the evidence package, the boundary-exposure check, and the SSP/POA&M draft — so the state is *measured*, not asserted.
- **Lower cost, faster.** Self-guided steps replace open-ended readiness consulting; the certification determination stays where it belongs (your assessor).

Limitations (boundary restated)

- **No assessment result or certification.** Configuration and evidence only; the C3PAO determines conformance.
- **No applicability/scoping/legal call.** Which requirements apply, what counts as CUI, and any ITAR/DFARS interpretation are your compliance/legal/assessor's to make.
- **Vendor behavior may vary by edition/rollout.** Assured Controls, data-region, client-side encryption, and some log-export/DLP capabilities depend on your **Workspace edition and add-ons** and on features that roll out over time. Every such item is flagged **"verify your edition / Assured Controls availability in your tenant."** This solution never asserts a Google feature exists or behaves a certain way beyond current public documentation.

Requirements

These are the **solution-specific** prerequisites for CMMC Level 2 readiness on Google Workspace. They are **in addition to** the shared category prerequisites in `global-requirements-google.md` (a provisioned Workspace/Cloud-Identity tenant with super-admin, DNS control, an identity source of truth, a pilot OU/group and change control, and engaged security/compliance/governance stakeholders). Do not re-satisfy those here — verify them, then confirm the following.

> ***Scoping/applicability is not a prerequisite you satisfy technically.*** *Whether CMMC Level 2 and specific NIST 800-171 requirements apply to your organization, and what constitutes CUI, are* ***determinations for your compliance/legal team and assessor****. The requirements below prepare the *environment and inputs*; they do not decide scope.*

1. Workspace edition/add-on that supports the regulated-workload controls

• **Description:** A Google Workspace edition (and any add-on) that provides the controls CMMC L2 readiness relies on: **Vault** (retention/eDiscovery), **DLP for Drive/Gmail**, **context-aware access**, **data regions**, **audit-log export**, and — where the CUI workload requires it — **Assured Controls** and **client-side encryption**.

• **Why required:** Several NIST 800-171 families (AU, MP, SC, AC) are implemented through these features; without the edition/add-on they are unavailable.

• **How to verify:** In the **Admin console** → **Billing** → **Subscriptions**, confirm the edition and any Assured Controls / AppSec add-on. In **Account** → **Account settings** → **Legal & compliance** / **Data regions**, confirm data-region and (if licensed) Assured Controls surfaces are present. **Verify Assured Controls availability in your tenant** — it is edition/contract-dependent.

• **How to implement if missing:** Engage Google or your reseller to move to the qualifying edition and enable the required add-ons **before** configuration. Flag any capability you cannot confirm as a **POA&M** item rather than assuming it exists.

2. A defined CUI boundary input (users, groups, Shared Drives, data flows)

• **Description:** A documented list — even a draft — of **who handles CUI**, **which groups/OUs they belong to**, which Shared Drives / shared locations hold CUI**, and** how CUI enters and leaves** (mail, Drive sharing, external collaboration, connected apps). This is the input to the `CUI – Boundary – Org` OU.

• **Why required:** The boundary defines assessment scope; every subsequent control is applied *to the boundary*. Without it, scope is unbounded and evidence is unfocused.

• **How to verify:** Confirm a data map / CUI inventory exists (from the compliance/data-governance stakeholders named in the shared requirements). The included boundary-exposure tool can help *validate* a draft, but the **authoritative determination of what is CUI is your compliance team's**.

• **How to implement if missing:** Work with data-governance/compliance to produce a first-pass CUI inventory and data-flow map; refine it during the Assess stage. Treat unknowns as boundary risks.

3. Assessor / C3PAO and compliance-owner engagement

• **Description:** A named **compliance owner** (accountable for the SSP/POA&M and the SPRS score) and,

ideally, the **C3PAO or Registered Practitioner** the organization intends to use — engaged early so the readiness work targets their expectations.

• **Why required:** Applicability, scoping, evidence-format expectations, and the ultimate determination are theirs. Building readiness without them risks re-work.

• **How to verify:** Confirm the compliance owner is identified and that assessor expectations (scope, evidence format, SSP template) are known or requested.

• **How to implement if missing:** Identify the compliance owner before authoring the SSP; engage a C3PAO/RP per your organization's procurement process. **This solution does not select or represent an assessor.**

4. Baseline of the existing Assured Controls / data-region posture

• **Description:** Knowledge of the current **data-region policy**, **Assured Controls state**, and **client-side-encryption** configuration for the CUI OUs — typically established by the separate Assured Controls / ITAR / DFARS solution.

• **Why required:** NIST 800-171 SC (System & Communications Protection) and MP (Media Protection) controls reuse this posture; the readiness work maps to it rather than rebuilding it.

• **How to verify:** Review the data-region/Assured Controls configuration for the CUI OUs in the Admin console and confirm it matches the organization's documented regulated-workload design.

• **How to implement if missing:** Complete the Assured Controls / data-region work first (separate solution), then return to map those controls into the SSP.

5. API access for the assessment and evidence tooling

• **Description:** A **Google Cloud project** with the **Admin SDK (Directory + Reports)**, **Drive**, and **Groups Settings** APIs enabled, plus an OAuth client or a service account with **domain-wide delegation** limited to **read-only** admin scopes, for running the five Python tools.

• **Why required:** The tools read directory, policy, sharing, and audit-log data to produce the control-status map and evidence package. They are read-only/dry-run by default.

• **How to verify:** In the Cloud console confirm the APIs are enabled; run `assess-nist-controls.py --check-auth` (below) to confirm the credential authenticates with read-only scopes.

• **How to implement if missing:** Create the project, enable the APIs, and configure a **least-privilege read-only **credential (OAuth user consent or a delegated service account restricted to the `*.readonly` **admin scopes).** Never **grant write scopes to the evidence tooling;** never** commit or export the credential. Store secrets outside the repo (ADC / a secured secret store).

6. Change-control window scoped to CUI-boundary changes

• **Description:** Beyond the shared change-control prerequisite, a change window and rollback plan specifically for the **high-impact CUI-boundary controls** — DLP enforcement, external-sharing restriction, context-aware access, and audit-log export — because these affect users' ability to send mail and share files.

• **Why required:** Enforcing these fleet-wide without a pilot and rollback can block legitimate work or break collaboration. The deployment model requires a documented rollback for each.

• **How to verify:** Confirm an approved window and a named rollback owner for the CUI-boundary changes.

• **How to implement if missing:** Agree the window and rollback path with the change-control and business owners before the Configure stage.

Global Requirements — Google Workspace & Gemini Solutions

These requirements apply to **every** solution in the **Google** category. They are the common foundation each Google Workspace / Gemini solution assumes is already in place (or stands up as part of its own Requirements section). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Google solution).*** *The **Google Admin console** (admin.google.com), **Google Cloud / Cloud Identity**, and the **Microsoft / Entra** sides are authored at exact, current click-by-click detail from the vendors' public documentation. **Gemini Enterprise** capabilities that are in preview or rolling out are **cited or flagged "verify in your tenant"** — never invented. **Third-party migration tools** (e.g. for mail/Drive/Chat data movement) and **third-party enterprise apps** (ServiceNow, SAP, Databricks, etc.) are integrated at the pattern/architectural level; their internal console steps are deferred to the vendor's own docs.*

1. Google Workspace / Cloud Identity tenant

• **Description:** A provisioned Google Workspace (or Cloud Identity) tenant with a **super-admin** account for configuration, and the appropriate Workspace edition/licensing for the capability in scope (e.g. Enterprise Plus for Vault/CAA/DLP, Gemini/AI add-on where required).

• **Why required:** All configuration, policy, and API work is performed against this tenant.

• **How to verify:** Sign in to **admin.google.com** as a super-admin; confirm edition and license counts under **Billing / Subscriptions**.

• **How to implement if missing:** Provision the tenant and licenses through Google or an authorized reseller before starting.

2. Source Microsoft 365 / Entra environment (for migration & coexistence)

• **Description:** For migration/coexistence/identity solutions, administrative access to the source **Microsoft 365** tenant and **Microsoft Entra ID** (Global Administrator or the least-privilege roles the solution names).

• **Why required:** Migration, directory sync, SSO federation, and coexistence read from and change the Microsoft side.

• **How to verify:** Confirm access to the M365 admin center and the Entra admin center with the required role.

• **How to implement if missing:** Obtain the role from the M365/Entra tenant owner.

3. DNS control for the routed domains

• **Description:** Ability to create/modify **DNS records** (MX, SPF, DKIM, DMARC, TXT, CNAME) for the domains being migrated, coexisting, or verified.

• **Why required:** Domain verification, mail routing/coexistence, and authentication all depend on DNS changes.

• **How to verify:** Confirm access to the authoritative DNS zone for each domain.

• **How to implement if missing:** Coordinate with whoever controls DNS; stage changes under change control (mail-flow changes are high-impact).

4. Identity & provisioning source of truth

• **Description:** A defined **identity source of truth** (on-prem AD, Entra ID, or an HR/IGA system) and the sync mechanism (e.g. **Google Cloud Directory Sync (GCDS)** or SCIM-based provisioning).

• **Why required:** Consistent users/groups across ecosystems underpin SSO, licensing, and access.

• **How to verify:** Confirm which directory is authoritative and how objects flow into Google.

• **How to implement if missing:** Define the source of truth and provisioning model before configuring SSO or migrating.

5. A pilot scope (OU / group) and change control

• **Description:** A **pilot organizational unit or group** to validate on before fleet-wide rollout, and a **change-control** process for production changes (especially mail flow, DNS, identity, and DLP).

• **Why required:** Every solution follows an **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model; the pilot proves the design and change control protects production.

• **How to verify:** Confirm a named pilot OU/group exists and a change window/approval path is available.

• **How to implement if missing:** Create a pilot OU/group and agree the change-control process with the owners before making production changes.

6. Security, compliance & governance stakeholders

• **Description:** Engagement with the **security (CISO), legal/eDiscovery, and data-governance** stakeholders whose policies the configuration must satisfy (DLP, retention, Vault/Purview, and any regulatory regime such as ITAR/DFARS/Assured Controls where applicable).

• **Why required:** Data governance, eDiscovery, DLP, and regulated-workload settings must align to enterprise policy and legal requirements, not just technical defaults.

• **How to verify:** Confirm the applicable policies and named stakeholders/approvers.

• **How to implement if missing:** Identify the owners and obtain the policy/compliance requirements before configuring governance controls.

*The deployment model across every Google solution is the same: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand**, with explicit pass/fail gates and a documented rollback for production changes.*

Implementation

Follow these stages in order: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand**. Every artifact is **named to a convention** and reused verbatim later. Every high-impact production change is **piloted first** and has a **rollback**. **Certification determinations are out of scope** — this produces configuration and evidence; your assessor determines conformance.

Naming conventions used throughout (create once, reuse exactly):

Artifact	Name
CUI boundary OU	`CUI – Boundary – Org`
CUI enclave sub-OU (optional)	`CUI – Enclave – Org`
Pilot group	`CUI – Pilot – Org`
Control map (matrix)	`NIST 800-171 – Control Map – Org`
DLP rule (Drive/Gmail)	`DLP – CUI – Enforce` (pilot: `DLP – CUI – Monitor`)
External-sharing policy	`Sharing – CUI Boundary – Restricted`
Context-aware access level	`CAA – CUI Boundary – Enforce`
Retention rule (Vault)	`Retention – CUI – Org`
Audit-log export sink	`AuditExport – CUI – Org`
Evidence package	`Evidence – CUI Boundary – <YYYY-MM-DD>`
System Security Plan	`SSP – CUI Boundary – Org`
Plan of Action & Milestones	`POA&M – CUI Boundary – Org`

Stage 1 — Assess (read-only, no changes)

1. **Confirm scope inputs.** Gather the CUI inventory / data-flow map (Requirement 2) and the compliance owner's expectations (Requirement 3). Record which of the 110 requirements the compliance team considers **in scope** — **do not decide this yourself; it is their determination.**

1. **Baseline the tenant.** Run the assessment tool read-only to capture the current state of every mappable control:

```
python assess-nist-controls.py --domain corp.example --out control-map.csv
```

This produces the first draft of the `NIST 800-171 – Control Map – Org` matrix: for each control it records the Workspace setting it maps to, the observed value, and a **status** (`configured` / `partial` / `not-configured` / `manual` / `verify-edition`).

1. **Baseline the boundary exposure.** Run the boundary checker read-only over the draft CUI OU/groups:

```
python cui-boundary-check.py --ou "/CUI – Boundary – Org" --out boundary-exposure.csv
```

Record external-sharing exposure, non-member access, and mail-flow to external domains as **findings** (not yet remediated).

1. **Gate 1 (Assess complete):** Control-map draft exists with a status for all in-scope requirements;

boundary-exposure findings captured; compliance owner has confirmed the in-scope requirement set. **Fail** → resolve missing inputs before designing.

Stage 2 — Design

1. **Draw the boundary.** Design the `CUI – Boundary – Org` OU (and `CUI – Enclave – Org`

sub-OU if a stricter enclave is warranted): which users move in, which Shared Drives are in scope, which groups gate access.

1. **Design the control-to-setting mapping.** For each in-scope requirement, decide the concrete

Workspace mechanism (see the family map below) and the **artifact name** that will implement it. Update the control map's "planned setting" column.

1. **Design the evidence model.** Decide, per control, what constitutes evidence: a config export, an

audit-log extract, or a documented manual procedure (for the non-technical families such as PS/PE/AT).

1. **Design rollback** for each high-impact change (DLP, sharing, CAA, log export): the exact prior

value and how to restore it.

1. **Gate 2 (Design complete):** Every in-scope requirement has a planned mechanism + evidence type +

(for high-impact ones) a rollback. Compliance owner has reviewed the SSP outline.

NIST 800-171 family → Google Workspace mechanism (design reference)

Map at this level; the exact click-path is validated against **current Google documentation** and your edition. Items marked **(verify edition)** depend on your Workspace edition / Assured Controls add-on.

Family	Primary Workspace mechanism(s)
AC Access Control	OU/group membership on `CUI – Boundary – Org`; `Sharing – CUI Boundary – Restricted` external-sharing policy; `CAA – CUI Boundary – Enforce` context-aware access; Shared Drive member/role limits; admin role separation
AT Awareness & Training	Documented CUI-handling training + attestation records (**manual evidence**)

Family	Primary Workspace mechanism(s)
AU Audit & Accountability	Admin/login/Drive/Gmail **audit logs**; `AuditExport – CUI – Org` log export to a retained sink; log review procedure
CM Configuration Management	Baseline of OU policies; change-control records; app allow/deny (Marketplace + API access) for the boundary OU
IA Identification & Authentication	Enforced **2-step verification / security keys**; SSO/identity source; session-length policy; no shared accounts
IR Incident Response	Alert Center / audit-driven detection; documented IR procedure and reporting path (**manual + tooling evidence**)
MA Maintenance	Admin-action logging for maintenance; least-privilege admin roles (**mostly manual/managed-service evidence**)
MP Media Protection	Data-region / **client-side or default encryption (verify edition)**; DLP-controlled export; device-policy controls
PS Personnel Security	Onboarding/offboarding tied to identity source; suspension on separation (**manual + directory evidence**)
PE Physical Protection	Inherited from Google data-center controls (cite Google compliance docs) + endpoint physical controls (**manual/inherited evidence**)
RA Risk Assessment	Vulnerability/risk process; this readiness assessment itself (**manual evidence + control map**)
CA Security Assessment	The SSP, POA&M, and continuous control monitoring (this solution's outputs)
SC System & Communications Protection	TLS/mail security (SPF/DKIM/DMARC), **data regions / Assured Controls (verify edition)**, encryption in transit/at rest, boundary separation
SI System & Information Integrity	DLP (`DLP – CUI – Enforce`), Gmail security sandbox/attachment controls, alerting, flaw-remediation process

Stage 3 — Configure (against the boundary OU)

Perform each change in the Admin console (paths **verified against current Google documentation**; where a label/path is version-dependent, **verify in your tenant**), and record the resulting value in the control map. Configure on the OU, not the whole domain.

1. **Create/confirm the boundary OU** `CUI – Boundary – Org` and move the in-scope users into it;

create the `CUI – Pilot – Org` group as a subset for piloting.

1. **AC — external sharing:** apply `Sharing – CUI Boundary – Restricted` (Drive external-sharing

restricted/allow-listed) to the OU. **Rollback:** restore the OU's prior sharing setting.

1. **AC — context-aware access:** create access level `CAA – CUI Boundary – Enforce` and assign it

to the CUI apps for the OU. **Rollback:** unassign the access level.

1. **IA — 2SV / keys:** enforce 2-step verification (security keys where required) for the OU;

configure session length. **Rollback:** revert enforcement to prior state.

1. **SI/MP — DLP:** create the DLP rule, first as `DLP – CUI – Monitor` (audit action) for the

pilot, later promoted to `DLP – CUI – Enforce` (block/warn). **Rollback:** set the rule to monitor/off.

1. **AU — audit-log export & retention:** configure `AuditExport – CUI – Org` (log export/BigQuery

or your retained sink) and the `Retention – CUI – Org` Vault rule. **Rollback:** disable the export sink / retention rule.

1. **SC/MP — data region & encryption:** confirm the CUI OU's **data-region** policy and, where the

workload requires and the edition supports it, **client-side/default encryption** — **verify Assured Controls / encryption availability in your tenant**; if unavailable, record a **POA&M** item rather than asserting the control.

1. **CM — app control:** restrict Marketplace/third-party app and API access for the boundary OU to an

allow-list. **Rollback:** restore prior app-access setting.

1. Record every configured value and its **evidence pointer** in `NIST 800-171 – Control Map – Org`.

Stage 4 — Pilot (`CUI – Pilot – Org`)

1. Apply the enforcing variants (DLP monitor→warn, CAA, sharing restriction, 2SV) to the **pilot group

only**.

1. Run the validation suite (see 05-testing) against the pilot; confirm legitimate work is not blocked

and controls behave as designed.

1. **Gate 3 (Pilot pass):** All pilot validations pass and no legitimate-workflow breakage. **Fail** →

tune the rule (e.g. DLP detector, sharing exception) and re-pilot; **do not expand on a failed pilot.** Rollback the pilot changes if unrecoverable.

Stage 5 — Validate & evidence

1. **Collect evidence** across the boundary OU:

```
python collect-evidence.py --ou "/CUI – Boundary – Org" --package "Evidence – CUI Boundary – 2026-07-0
```

This exports the **configuration state** (policies/settings, read-only) and the **operational evidence** (audit-log extracts, read-only) into the named package, indexed to the control map.

1. **Generate the SSP + POA&M drafts** from the completed control map:

```
python generate-ssp-poam.py --control-map control-map.csv --out-ssp "SSP – CUI Boundary – Org.md" --ou
```

The SSP gets one implementation statement per requirement; the POA&M gets one row per `partial`/`not-configured`/`verify-edition` requirement with owner + milestone placeholders. **A human compliance owner reviews, corrects, and owns these — the tool drafts, it does not attest.**

1. **Gate 4 (Assessment-ready):** every in-scope requirement is `configured` **and** evidenced, **or**

tracked on the POA&M with an owner and milestone; the boundary-exposure check is clean; SSP and POA&M are complete and reviewed by the compliance owner. **This gate is readiness — not a certification.**

Stage 6 — Expand & sustain

1. Roll the enforcing controls from the pilot to the full `CUI – Boundary – Org` OU under the

change window, with rollback ready.

1. Schedule **continuous monitoring**: re-run `assess-nist-controls.py` and `cui-boundary-check.py` on a

cadence, refresh the evidence package before the assessment window, and keep the POA&M current.

1. **Hand off to the C3PAO/compliance team.** The assessment, the scoring submission to SPRS, and the

certification decision are **theirs** — this solution's responsibility ends at a reviewed, evidenced, assessment-ready posture.

> ***Rollback summary.*** *Each high-impact control (sharing, CAA, 2SV, DLP, log export, encryption) has a single documented prior value restorable from the control map. Because everything is applied to the* ***OU/pilot group*** *first, a rollback is scoped to the boundary and never touches the wider tenant.*

Testing & Validation

Run these after the Configure and Pilot stages, and again to refresh evidence before the assessment window. Each test states the **procedure** and the **expected pass/fail**. A test **passing** means the control is *configured and evidenced as designed* — it does **not** assert the control "satisfies" a NIST 800-171 requirement as an assessment matter; that determination is your assessor's.

Run validations against the `CUI – Pilot – Org` group first (Gate 3), then across the full `CUI – Boundary – Org` OU (Gate 4).

T1 — Boundary membership is correct

- **Procedure:** `python cui-boundary-check.py --ou "/CUI – Boundary – Org" --out boundary-exposure.csv`

then review membership against the CUI inventory.

• **Pass:** Every user/group/Shared Drive in the CUI inventory is inside the boundary OU, and no unexpected members are present.

• **Fail:** Missing in-scope members, or out-of-scope members present → correct OU membership and re-run before evidencing.

T2 — External sharing is restricted (AC)

• **Procedure:** As a boundary-OU user, attempt to share a CUI Drive file externally; also run the boundary checker's sharing scan.

• **Pass:** External sharing is blocked or limited to the allow-list per **`Sharing – CUI Boundary – Restricted`**; the checker reports no unexpected external exposure.

• **Fail:** External share succeeds outside policy → re-apply the sharing policy; re-pilot.

T3 — Context-aware access enforces (AC)

• **Procedure:** Access a CUI app from a context that violates `CAA – CUI Boundary – Enforce` (e.g. disallowed location/device state per your access level).

• **Pass:** Access is denied from the non-conforming context and allowed from a conforming one.

• **Fail:** Access allowed from a non-conforming context → verify access-level assignment to the OU's apps.

T4 — 2-Step Verification / keys enforced (IA)

• **Procedure:** Confirm a boundary-OU account cannot complete sign-in without the enforced second factor; review the 2SV enrollment report.

• **Pass:** 2SV (security keys where required) is enforced for 100% of boundary-OU accounts; no exempted accounts remain.

• **Fail:** Any boundary account without enforced 2SV → remediate before evidencing.

T5 — DLP detects and acts on CUI (SI/MP)

• **Procedure:** Send/share test content matching the CUI detector; in pilot the rule is `DLP – CUI – Monitor`, in enforcement `DLP – CUI – Enforce`.

• **Pass:** Monitor logs the event; Enforce blocks/warns as designed; no false-block of legitimate non-CUI content in the pilot sample.

• **Fail:** CUI content passes undetected, or heavy false positives → tune the detector; re-pilot. **Do not promote monitor→enforce fleet-wide on a failed pilot.**

T6 — Audit logging and export work (AU)

• **Procedure:** Perform a set of known admin and user actions in the boundary; confirm they appear in the audit logs and in the `AuditExport – CUI – Org` sink.

• **Pass:** All test actions are recorded and present in the exported/retained sink within the expected latency; retention rule `Retention – CUI – Org` is active.

• **Fail:** Missing events or export not populating → verify export configuration and retention rule.

T7 — Data region / encryption posture (SC/MP)

• **Procedure:** Confirm the boundary OU's data-region policy and (where licensed) encryption state via the Admin console and `assess-nist-controls.py`.

• **Pass:** Data region and encryption match the documented regulated-workload design. **Verify Assured

Controls / encryption availability in your tenant **— if a capability is unavailable by edition, this test** defers to a POA&M item** rather than failing the readiness gate.

• **Fail (actionable):** Configuration drifts from the documented design → re-apply; **capability unavailable by edition** → record on POA&M, not a hard fail.

T8 — App / API access controlled (CM)

• **Procedure:** From a boundary-OU account, attempt to authorize a non-allow-listed Marketplace/OAuth app.

• **Pass:** Authorization is blocked per the allow-list.

• **Fail:** Non-allow-listed app authorizes → re-apply app-access restriction.

T9 — Evidence package is complete and indexed

• **Procedure:** `python collect-evidence.py --ou "/CUI – Boundary – Org" --package "Evidence – CUI Boundary – <date>"` then review the package index against the control map.

• **Pass:** Every `configured` control has a matching config export and/or audit-log extract in the package, indexed to its control ID.

• **Fail:** A configured control has no evidence → collect the missing artifact.

T10 — SSP and POA&M are complete (CA)

• **Procedure:** `python generate-ssp-poam.py` …, then the compliance owner reviews.

• **Pass:** `SSP – CUI Boundary – Org` has an implementation statement for every in-scope requirement; `POA&M – CUI Boundary – Org` has a row (owner + milestone) for every partial/not-configured/verify-edition requirement; the compliance owner has reviewed and accepted the drafts.

• **Fail:** Any in-scope requirement missing an SSP statement or an unmet requirement missing from the POA&M → complete before declaring assessment-ready.

Overall readiness gate (Gate 4): T1–T10 pass (with T7 edition-gaps parked on the POA&M), and the compliance owner has accepted the SSP + POA&M. At this point the environment is **assessment-ready**. The C3PAO assessment and its outcome remain out of scope.

Troubleshooting

Common failure modes during CMMC Level 2 readiness on Google Workspace, and how to resolve them. These address the **technical readiness and evidence** work — they do **not** resolve assessment, applicability, or legal questions, which stay with your assessor/compliance/legal team.

Authentication & API access

Symptom: `assess-nist-controls.py --check-auth` **fails, or tools return 401/403.**

• Confirm the service account has **domain-wide delegation** and that the delegated scopes in the Admin console **exactly match** the `*.readonly` scopes the tool requests (a superset or mismatch is rejected).

• Confirm `--subject` is a **super-admin (or sufficiently privileged) user** to impersonate.

• Confirm the **Admin SDK (Directory + Reports)**, **Drive**, and **Groups Settings** APIs are enabled in the Cloud project.

• Never work around this by granting **write** scopes to the read-only tools — fix the read-only grant.

Symptom: 403 "insufficient permission" only on the Reports/audit calls.

• The `admin.reports.audit.readonly` scope must be delegated *and* the impersonated user must have privilege to read audit logs. Add the scope and re-consent.

Throttling / rate limits

Symptom: 429 / `rateLimitExceeded` **/** `userRateLimitExceeded` **on large tenants.**

• The Admin SDK enforces per-project and per-user quotas. For large boundary OUs, run during off-peak, and page results (the tools already use `maxResults`); extend them with exponential backoff on 429 if you add deeper enumeration.

• Split very large evidence collections by application (`collect-evidence.py` already writes per-app files) or by time window (`--days`) to stay under quota.

• Request a quota increase for the Cloud project if sustained collection needs it.

Evidence gaps

Symptom: T9 fails — a `configured` control has no evidence in the package.

- Re-run `collect-evidence.py --live`; confirm the audit source that carries that control is included in

`AUDIT_SOURCES` and that the events actually occurred in the lookback window (perform the action, then re-collect).

- If a control is genuinely manual (AT/PS/PE/IR), its evidence is a **documented procedure/attestation**,

not an API export — attach it to the package by hand and index it.

Symptom: audit-log evidence is empty for an application.

- Log availability and latency vary by application and edition; some events surface with delay. Widen

the window and re-collect. If an application's logging is edition-gated, record it as a **POA&M** item ("verify-edition") rather than asserting the control.

DLP behaves unexpectedly

Symptom: DLP blocks legitimate work (false positives) in the pilot.

- Keep the rule as `DLP – CUI – Monitor` while tuning; review the hits, refine the detector

(thresholds, dictionaries, context), and only then promote to `DLP – CUI – Enforce`. **Do not** promote to enforce fleet-wide on a failing pilot (Gate 3).

Symptom: DLP misses CUI-shaped content (false negatives).

- Broaden/adjust the detector against sample CUI; validate with T5 before evidencing. Detector accuracy

is a tuning exercise — budget pilot iterations for it.

Boundary drift & scope errors

Symptom: `cui-boundary-check.py` reports external or out-of-OU members.

- High-severity **external-group-member** findings mean CUI groups admit external domains — remove them

or, if intentional and approved, document the exception with your compliance owner (acceptability is *their* call).

- **member-outside-boundary-ou** means a CUI-group member's account lives outside the boundary OU, so it

misses the boundary controls — move the account into `CUI – Boundary – Org`.

- Re-run after every joiner/mover/leaver; tie membership to the identity source to prevent recurrence.

Symptom: Drive external-sharing exposure suspected but not fully enumerated.

- The boundary checker flags Drive sharing as a follow-up: run a `Drive files.list` external-sharing scan

against your **shared-drive inventory** (read-only) to enumerate per-file exposure. The tool does not fabricate a private API for this — extend it against the documented Drive API.

Edition-gated features

Symptom: Assured Controls / data-region / client-side encryption not present in the console.

- These are **edition/contract/rollout dependent**. Confirm your edition and add-ons under **Billing →

Subscriptions**; if unavailable, this is** not a hard test failure **— record a** POA&M **item (**`verify-edition`**) and pursue the edition/add-on or a documented compensating control.** Never assert a control is met on a feature you cannot confirm exists in your tenant.**

SSP / POA&M generation

Symptom: `generate-ssp-poam.py` **errors "control map not found / empty".**

- Run `assess-nist-controls.py` first to produce the control-map CSV, then point `--control-map` at it.

Symptom: POA&M shows zero open items but you know gaps exist.

- The POA&M is generated from **status**. Zero open items means every row is marked `configured` — check

for **over-stated** statuses in the control map. Honest `partial`/`verify-edition` statuses are safer than an optimistic `configured` that becomes an assessment finding.

Rollback

Symptom: an enforcing control blocked users after expansion.

- Every high-impact control has a documented prior value in the control map. Restore it (set DLP to

monitor/off, unassign the CAA level, revert the sharing policy, disable the export sink) — the change is scoped to the boundary OU/pilot group, so rollback never affects the wider tenant. Re-pilot before re-expanding.

Best Practices

Durable practices for keeping a Google Workspace tenant CMMC Level 2 **assessment-ready** on NIST SP 800-171. These sustain the posture between the readiness engagement and the assessment — and after.

Boundary discipline

- **Keep the CUI boundary small and explicit.** The narrower and better-defined **`CUI – Boundary – Org`** OU is, the smaller and more stable your assessment scope. Resist letting CUI drift into general-population OUs or personal Drives.
- **One way in, one way out.** Route CUI ingress/egress through controlled paths (approved Shared

Drives, allow-listed external domains) so the data-flow map stays true and the boundary checker stays meaningful.

- **Re-validate membership on every joiner/mover/leaver.** Tie boundary-OU membership to the identity

source so personnel changes update scope automatically (PS family).

Evidence hygiene

- **Evidence is a product, not an afterthought.** For every control, capture *both* the configuration

state and operational proof (audit-log extract) — an assessor asks "show me it's on" *and* "show me it's working."

- **Timestamp and index every package.** Use the `Evidence – CUI Boundary – <date>` convention and

index each artifact to its NIST control ID, so the assessor can trace requirement → evidence in one step.

- **Refresh evidence close to the assessment.** Audit-log evidence ages; regenerate the package within

your assessor's expected freshness window.

- **Never let evidence collection require write access.** Keep the evidence tooling strictly read-only

so running it can never change the posture it is measuring.

Control-map as single source of truth

- **Drive everything from** `NIST 800-171 – Control Map – Org`**.** Control status, planned setting,

configured value, evidence pointer, and POA&M linkage all live in one matrix; the SSP and POA&M are generated *from* it, not maintained separately.

- **Status honestly.** Use `partial` and `verify-edition` truthfully; an over-stated `configured`

becomes an assessment finding. It is safer to carry an honest POA&M item than to assert a control you cannot evidence.

Change safety

- **Pilot every enforcing control.** DLP, context-aware access, sharing restriction, and 2SV can block

legitimate work; prove them on `CUI – Pilot – Org` with a rollback before fleet enforcement.

- **Monitor before you block.** Ship DLP as `DLP – CUI – Monitor` first, read the hits, then promote

to `DLP – CUI – Enforce`.

- **Document the rollback with the change.** Record the prior value in the control map at the moment you

change it, so rollback is a lookup, not an investigation.

Least privilege & credential safety

- **Read-only, least-scope credentials for tooling.** The five tools need only `*.readonly` admin

scopes; never grant them write scopes.

- **No secrets in the repo, ever.** Use OAuth user consent, ADC, or a secured secret store; never commit

a key, service-account JSON, or exported credential. Rotate the tooling credential on a schedule.

- **Separate admin duties.** Split super-admin, user-management, and compliance/eDiscovery roles (AC/MA

families); log and review admin actions.

Keep the assessment boundary where it belongs

- **Configure and evidence; let the assessor determine.** Treat every "meets control X" statement as

"*configured to support control X, pending assessor determination*." Do not self-certify, and do not interpret ITAR/DFARS applicability in the SSP — cite the framework and reference the compliance/legal team's determinations.

- **Verify edition-dependent features, don't assume them.** Assured Controls, data regions, and

client-side encryption vary by edition/rollout — confirm each in your tenant and POA&M anything you cannot confirm.

Continuous monitoring

- **Schedule re-assessment.** Re-run `assess-nist-controls.py` and `cui-boundary-check.py` on a regular

cadence; treat new `partial`/`not-configured` results as POA&M items immediately.

- **Keep the POA&M live.** A current POA&M with real owners and dates is itself evidence of a functioning

security-assessment (CA) process.

Deliverables Summary

Everything included in this CMMC Level 2 readiness solution for Google Workspace, on one page. The solution delivers **readiness** — control mapping, configuration method, and evidence, plus the SSP and POA&M. It does **not** produce a CMMC assessment result or certification; those remain with your assessor and compliance/legal team.

Documentation

Document	What it covers
Solution Overview	CMMC L2 / NIST 800-171 (14 families), the CUI boundary on Workspace, the reference model, benefits, limitations, and the deployment model.

Document	What it covers
Requirements Guide	Solution-specific prerequisites (edition/add-on for regulated controls, CUI-boundary input, assessor/compliance engagement, Assured Controls baseline, read-only API access, CUI-scoped change control) — each with verify/implement steps, on top of the shared Google requirements.
Implementation Guide	Assess → Design → Configure → Pilot → Validate → Expand: define the CUI boundary, map every family to a Workspace mechanism, configure + pilot + evidence, and generate the SSP/POA&M — with named artifacts, pass/fail gates, and rollbacks.
Testing & Validation	Ten tests (T1–T10) with expected pass/fail: boundary membership, sharing, context-aware access, 2SV, DLP, audit logging/export, data-region/encryption, app control, evidence completeness, SSP/POA&M completeness.
Troubleshooting	Common failure modes — API throttling/scope errors, incomplete evidence, DLP false positives, edition-gated features, boundary drift — with resolutions.
Best Practices	Boundary discipline, evidence hygiene, control-map-as-source-of-truth, change safety, least-privilege credentials, and holding the assessment boundary.
Executive Summary	Outcome, approach, and why the engagement is low-risk.

The 5 Python tools

All are **safe-by-default** (read-only or dry-run), use the Google Workspace **Admin SDK / Reports / Drive / Groups** APIs, take least-privilege scopes, and hold **no credentials or keys in code**.

Tool	What it does
`assess-nist-controls.py`	READ-ONLY. Maps the 14 NIST 800-171 families to Workspace settings and emits the `NIST 800-171 – Control Map – Org` matrix with a status per control (configured / partial / not-configured / manual / verify-edition). `--check-auth` verifies the credential.
`collect-evidence.py`	READ-ONLY. Exports configuration state (OU/user/group settings) and operational evidence (audit-log extracts) into a timestamped `Evidence – CUI Boundary – <date>` package, indexed to the control map.

Tool	What it does
`cui-boundary-check.py`	READ-ONLY. Scans the CUI boundary OU/groups for exposure — external Drive sharing, external/out-of-OU group members — and reports findings by severity (drives boundary tests T1/T2).
`generate-ssp-poam.py`	Local-only. Drafts the SSP – CUI Boundary – Org (statement per requirement) and POA&M – CUI Boundary – Org (row per open requirement) from the control map, for the compliance owner to review and own.
`cui-scope-helper.py`	DRY-RUN by default. Plans the named artifacts (boundary OU, pilot group, DLP/sharing/CAA/retention/export names) and the user→OU move list; with `--apply` performs only the low-risk, reversible scaffolding (create OU + pilot group, move users) — enforcing controls stay piloted/manual.

Outputs you finish with

- A completed NIST 800-171 – Control Map – Org matrix (control → setting → status → evidence).
- An indexed Evidence – CUI Boundary – <date> package (configuration + audit-log evidence).
- A clean **boundary-exposure** finding set.
- Reviewed SSP – CUI Boundary – Org and POA&M – CUI Boundary – Org documents.
- An **assessment-ready** tenant — configured, evidenced, and handed to your C3PAO/compliance team for

the determination.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

assess-nist-controls.py

collect-evidence.py

cui-boundary-check.py

cui-scope-helper.py

generate-ssp-poam.py